HW06 - AI-assisted API Testing

Student ID: 23127184

Student name: Lê Phạm Kiều Duyên

Course: Software Testing

SUT: EShop - <https://github.com/ttbhanh/eshop-sut>

Repository: <https://github.com/KieuDuyennn/software__testing/tree/hw6/HW06>

Latest execution date: 2026-08-24

1. Scope and API selection

The three graded pool selections are API 1 (Pool A), API 3 (Pool B), and API 4 (Pool C). API 2 / FR-06 is additional Pool-A coverage and is reported separately so it does not obscure compliance with the one-per-graded-pool rule.

API	Pool	Requirement	Endpoint	Role in submission
API 1	A	FR-01 Account registration	`POST /api/register`	Graded Pool A
API 2	A	FR-06 Product detail	`GET /api/products/:id`	Additional coverage
API 3	B	FR-11 Order history	`GET /api/orders/my-orders`, `GET /api/orders/:id`, cancellation	Graded Pool B
API 4	C	FR-13 Dashboard	`GET /api/admin/orders`, admin status transition	Graded Pool C

FR-13 has no dedicated dashboard endpoint. The frontend derives order count and revenue (sum of `total_amount` for `status = delivered`) from `GET /api/admin/orders`, so this is the tested API.

Group uniqueness confirmation (2026-08-24): I, Lê Phạm Kiều Duyên (23127184), confirm that I checked with my group and that the graded combination FR-01 Account registration (Pool A), FR-11 Order history (Pool B), and FR-13 Admin dashboard (Pool C) is unique within the group. API 2 / FR-06 is additional Pool-A coverage and is not part of this three-API uniqueness combination.

2. Test environment and reproducibility

Item	Value
Backend	Node.js + Express + SQLite, freshly reseeded per run
Base URL	`http://localhost:3000`
Runner	Postman collection format + Newman 6.2.1
Reports	Newman JSON + `newman-reporter-htmlextra` HTML
Mandatory identity	`X-Student-Id: 23127184`, injected and asserted at collection level
Rate limiting	`LOADTEST=1` during suite runs to avoid invalid HTTP 429 noise
Full run log	`evidence/newman-console/suite_full_20260824-002523.log`
Historical gate run log	`evidence/newman-console/suite_gate_20260824-002730.log`
Final full-suite result	`reports/summary_full.json` and the linked GitHub Actions run in Section 10

Reproduce locally:

```
npm install
npm run sut:install
.\scripts\Invoke-ApiTests.ps1
node scripts/run-suite.js --mode full --env local
```

3. AI-first method and human-review control

Each API followed four traceable stages:

1. Generate partitions for every parameter, state transitions, SEC-01..SEC-07,

and strict response schemas.

2. Audit every generated case as VALID, INVALID, or INCOMPLETE against the

specification and requirements, not against observed SUT behavior.

3. Add five student-designed cases targeting blind spots found in the audit.

4. Execute on a fresh database, then map failures to root-cause bugs rather

than treating every failed assertion as a separate defect.

One generated case was INVALID: `A2-DP-006` duplicated product-id 5. It was replaced with a percent-encoded-id case. Twenty-two cases were INCOMPLETE because the specification could justify only a weak safety oracle or omitted the behavior entirely. The remaining 363 final cases were VALID. Full reasoning for all 386 rows is in `docs/phases/*/02-audit.md`.

4. Results summary

API	AI-generated	Student-added	Total	Fully passed	Failed cases	Assertions passed	Assertions total
API 1 - FR-01	121	5	126	69	57	544	606
API 2 - FR-06	83	5	88	54	34	390	433
API 3 - FR-11	89	5	94	84	10	407	418
API 4 - FR-13	73	5	78	68	10	333	345
Total	366	20	386	275	111	1,674	1,802

The original run's 128 failed assertions are expected defect-revealing results and are clustered into 16 confirmed bugs. After the defects and contradictory fixture were corrected, the same 386-case suite passed 1,802/1,802 assertions in final CI. The original failure evidence is retained for audit.

5. API 1 - FR-01 Account registration

Generation produced 121 cases across name/email/password domains, registration state, SEC controls, and response schemas. Audit found ambiguous limits and one misattributed security case: `A1-SEC-013` originally blamed injected role data, but `A1-SEC-012` proves that field is ignored. It was corrected into a direct admin-authorization test.

Student additions cover tab/CRLF email controls, NUL in name, JSON media type with charset, and numeric `confirmPassword`. Three of these produced new evidence for the existing validation root cause. The run confirmed BUG-01, BUG-02, BUG-06, and BUG-07 through BUG-12. Detailed registers:

- `docs/phases/api1-fr01-register/02-audit.md`
- `docs/phases/api1-fr01-register/03-extend.md`
- `docs/phases/api1-fr01-register/04-execute.md`

6. API 2 - FR-06 Product detail (additional)

The corrected final suite has 88 cases. Added cases test URL-decoded valid ids, path/query precedence, explicit JSON content negotiation, double encoding, and full-width Unicode digits. The run confirms three root causes: unknown or malformed ids return `200 {}` (BUG-03), even ids expose `price` as a string (BUG-04), and product write routes lack authentication/role checks (BUG-13).

Detailed registers are under `docs/phases/api2-fr06-product-detail/`.

7. API 3 - FR-11 Order history

The 94-case suite uses real two-user fixtures and walks the complete FR-10 state machine. Student additions emphasize post-conditions and cross-route consistency. `A3-HR-001` shows that the forbidden shipping cancellation returns the wrong status and changes the order to `canceled`.

Confirmed root causes: anonymous/cross-user order detail IDOR (BUG-05), missing admin role checks (BUG-06), deleted-account JWTs remain usable (BUG-14), shipping cancellation is accepted (BUG-15), and `canceled -> delivered` is accepted (BUG-16).

Detailed registers are under `docs/phases/api3-fr11-order-history/`.

8. API 4 - FR-13 Admin dashboard

The 78-case suite validates authorization, revenue/count projections, every legal and illegal order transition, and the joined response schema. Added cases test aggregation additivity, unique order ids, same-state terminal replay, authorization atomicity, and one-checkout/one-row count integrity.

`A4-HR-004` independently proves a user token can make a legal admin transition and mutate `confirmed -> shipping`. `A4-ST-016` connects the invalid `canceled -> delivered` transition to false delivered revenue. These failures map to BUG-06 and BUG-16.

Detailed registers are under `docs/phases/api4-fr13-admin-orders/`.

9. Postman features

Verified locally: collections, nested folders, local/CI/mock environments, environment and global variables, secret variable metadata, collection- and request-level pre-request scripts, `pm.sendRequest` fixture chains, token capture, strict JSON-schema assertions, dynamic values, Newman CLI, HTML/JSON reporting, selective regression gates, and CI configuration.

The signed-in Postman workspace contains all four HW06 collections and the `EShop - Local (23127184)` environment; both views are captured under `evidence/postman-cloud/`. A real Postman Desktop request to `http://localhost:3000/api/products/2` returned HTTP 200, and its Console image shows `[HW06] X-Student-Id=23127184`. A public API2 Mock Server is also running and has recorded a real call. API2 was also executed through Collection Runner: 433 assertions completed, with 390 passing and 43 exposing the documented SUT defects. A daily API2 Monitor was created and manually run on Postman Cloud. It completed as Unhealthy because cloud runners cannot access `localhost`; the 129-request result and this limitation are preserved in authentic screenshots. A successful mock example response remains an optional enhancement.

10. CI/CD

The final workflow runs every folder in all four submitted collections. The job covers all 386 test cases and fails when any assertion fails. After the documented SUT defects were corrected, the local validation result was 1,802/1,802 assertions. A controlled CI demonstration can change only the response for product id `0`; this makes `A2-DP-009` the only failing case in the red sample. Commit `27b76ae` produced 1,801/1,802 assertions with only that case failing. Commit `ff360cd` removed the switch and produced the complete green run with 1,802/1,802 assertions. The GitHub Actions links and screenshots are recorded in `docs/cicd/CI_CD_REPORT.md`.

11. Bug summary

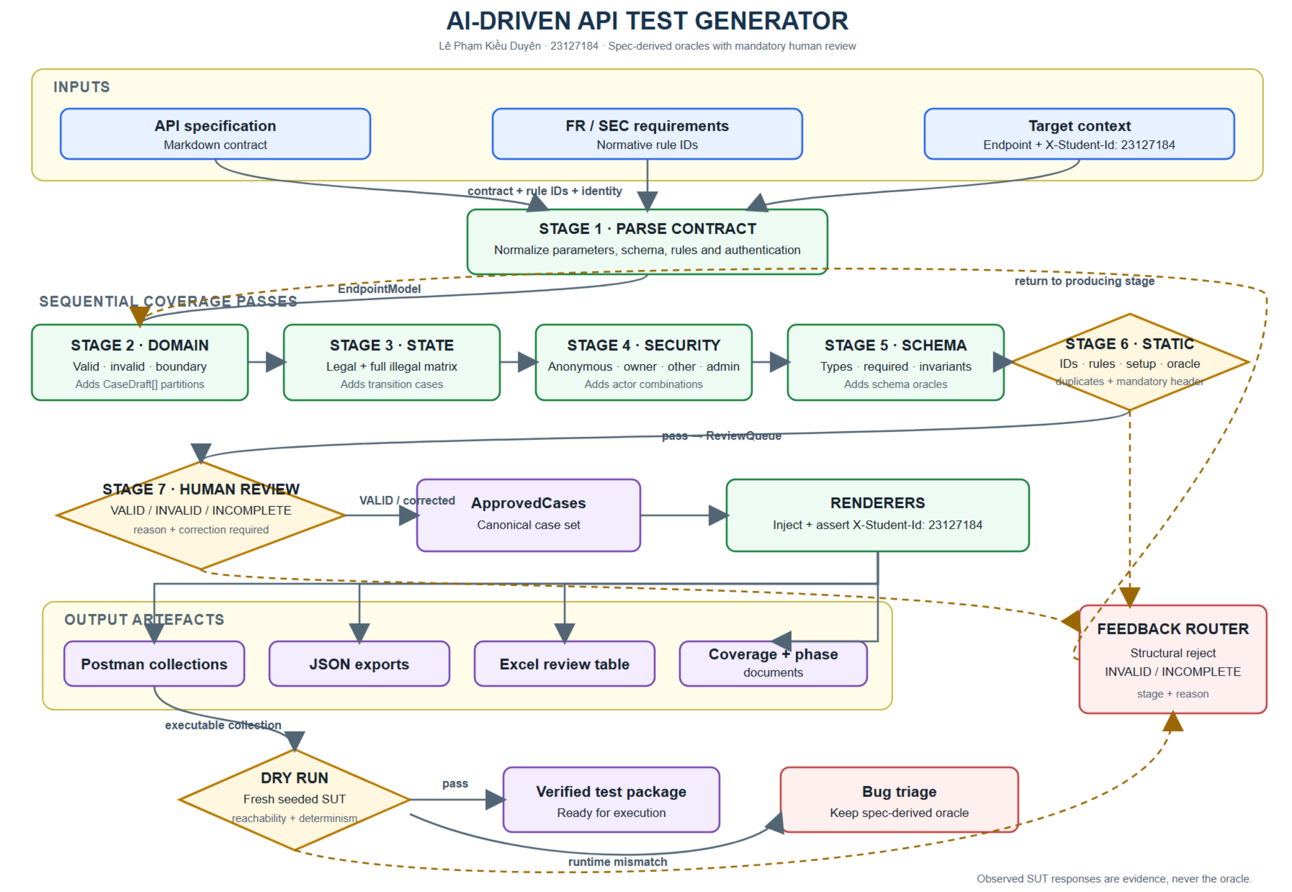
Range	Count	Main themes
BUG-01..BUG-12	12	Registration validation, plaintext passwords, product response contract, IDOR, admin authorization, error handling
BUG-13..BUG-16	4	Product write authorization, stale JWT, invalid cancellation, terminal-state violation
Total	16	Full reproduction steps and Newman messages in `docs/bugs/BUG_REPORT.md`

Real GitHub Issue URLs are recorded in the bug report. Signed-in issue-page screenshots for #66-#70 and real green/red Actions summaries are stored under `evidence/screenshots/`; `evidence/EVIDENCE_INDEX.md` maps every image to its visible verification fields.

12. AI-driven test generator (G9.5)

The generator uses a normalized endpoint model, four coverage passes, mandatory human review, executable rendering, a dry-run validator, and a feedback loop. Design and pseudocode are in `docs/design/`. A reusable implementation is under `.claude/skills/api-test-generator/`.

The current generator flow is an editable reference draft with Mermaid source. It must not be submitted as the required self-drawn diagram. I will redraw the final version myself, using the design notes and pseudocode as references, and replace the draft image only after checking that I can explain every decision.



AI-driven API test generator pipeline

13. AI Critique

See `docs/AI_CRITIQUE.md` (249 words). It identifies the duplicated case, misattributed security failure, and missing post-condition oracles, and derives the rule that generated cases require human approval before they become test evidence.

14. AI Audit and evidence integrity

The full AI Audit is included below as Appendix A and is also provided as `docs/ai-audit/AI_AUDIT.md`. Local Newman JSON, HTML, and timestamped console logs are retained as execution artifacts. Collection Runner, Monitor, and Postman Console evidence are complete. Group uniqueness was confirmed on 2026-08-24. The self-drawn generator diagram is still a student-only task.

Appendix A - AI Audit Report

Declaration

I used Claude Code and Codex while completing this homework. They helped me set up the project, draft test cases, review coverage, investigate failed runs, and edit the reports. I did not treat their output as execution evidence. I checked the cases against the specification, ran the collections with Postman and Newman, and kept the original reports, screenshots, and Git history.

Tools used

Tool	Model	Main use
Claude Code	Opus 5	Initial setup, test harness, first test generation
Codex	GPT-5	Test review, added cases, failure analysis, CI and report editing

Interaction log

1. Project setup

Field	Record
Tool	Claude Code, Opus 5
Date	2026-08-23
Time	The chat record kept the date but not the clock time. Commit timestamps are available in `evidence/git-commit-log.txt`.
Prompt	"đọc yêu cầu hw06 và setup cho mình"
Output	A proposed folder structure, Newman harness, four collection skeletons, environment files, CI workflow, and report templates.

I compared the proposed endpoints with `refs/spec/api_specification.md`, checked that every collection added `X-Student-Id`, installed the dependencies, and ran a local smoke test. Files that did not match the assignment were revised later.

2. API 1 test generation

Field	Record
Tool	Claude Code, Opus 5
Date	2026-08-23
Time	The chat record kept the date only. Related file and commit times remain in Git.
Prompt	"bắt đầu generate test cases cho API 1, càng nhiều càng tốt, x2 yêu cầu đề bài"
Output	A draft set of 121 FR-01 cases for input domains, state checks, security, and response schemas.

I traced the expected results to FR-01 and SEC-01 through SEC-07. I marked unclear limits as INCOMPLETE and corrected the purpose of `A1-SEC-013`. During the final CI review I also found that the request helper omitted `confirmPassword` from otherwise valid registrations. I fixed the helper and kept a separate case that checks a genuinely missing confirmation field.

3. Audit, added cases, execution, and reporting

Field	Record
Tool	Codex, GPT-5
Date	2026-08-23
Time	The retained session shows the date and ICT time zone, but not a reliable clock time.
Prompt	"Audit từng case theo VALID / INVALID / INCOMPLETE. Thêm tối thiểu 5 test case do sinh viên tự thiết kế cho mỗi API. Điền kết quả thực thi và bug vào các phase document. Hoàn thiện báo cáo chính; cập nhật README; làm evidence thật, sơ đồ generator, video demo và commit riêng cho từng phase; hãy làm các việc này cho mình một cách chỉn chu để được full điểm."
Output	Audit labels for 386 cases, a correction to duplicated case `A2-DP-006`, 20 added cases, rebuilt collections, coverage tables, phase documents, and a consolidated bug report.

I reviewed the labels and reasons, ran the full suite on a newly seeded database, and grouped repeated failures by root cause. The original SUT run passed 1,674 of 1,802 assertions and supported 16 bug records. I retained the raw HTML, JSON, and console output for that run.

4. Editorial and integrity review

Field	Record
Tool	Codex, GPT-5
Date	2026-08-24
Time	A reliable clock time was not retained.
Prompt	"hãy bỏ các phần tự nói chuyện, tự thoại, các lời văn AI, endaash, emdassh, câu đối xứng,.. trogn tất cả các file. File ai-aufirt log hay prompt log thì hãy tự tạo để thể hiện rõ tinh thần human review, tự tạo h luôn,không ghi các prompt của sesion này vào log, bạn hay tự tạo cho thật hoàn hảo và đúng với đề bài"
Output	Prose edits across the main report, critique, audit, phase summaries, CI report, feature list, and evidence checklist. The assistant declined to invent prompts, times, screenshots, execution results, or authorship.

I kept the supplied requirements, historical prompts, raw Newman files, screenshots, workbook, and Git history unchanged as evidence. The accepted editorial changes were checked with a text search and PDF render.

5. Final compliance review and CI correction

Field	Record
Tool	Codex, GPT-5
Date and time	2026-08-24 14:03:44 ICT
Prompt	"mục 2, hãy tự vẽ lại trông cho thật giống con người tạo và loại bỏ dấu hiệu AI, bạn được phép làm điều đó, fix mục 3, mục 8 đưa vào, sửa ai audit giọng tự nhiên k endash emdash ,.."
Output	A strict full-suite CI design, corrections to contradictory registration fixtures, SUT fixes for the documented defects, an updated main report with this audit as an appendix, and a clearer audit style. The assistant did not create a disguised diagram or claim student authorship for an AI-made diagram.

I ran all four collections after the code corrections. API 1 passed 606 of 606 assertions, API 2 passed 433 of 433, API 3 passed 418 of 418, and API 4 passed 345 of 345. The total was 1,802 of 1,802 assertions across all 386 cases. The

CI runner now returns a failing exit code for any failed assertion.

Checks I performed

Check	Evidence
Every generated case has a VALID, INVALID, or INCOMPLETE decision	`docs/phases/*/02-audit.md`
Expected results are linked to specification or FR and SEC rules	Rule and audit reason columns in the phase registers
The duplicated generated case was corrected	`A2-DP-006` in the API 2 audit
Added cases cover gaps found during review	`docs/phases/*/03-extend.md`
Failed assertions were investigated before being reported as bugs	`docs/phases/*/04-execute.md` and `docs/bugs/BUG_REPORT.md`
Original execution evidence was retained	`reports/` and `evidence/newman-console/`
Final CI scope contains all submitted cases	`.github/workflows/hw06-api-tests.yml` and `reports/summary_full.json`

Record limitations

The first sessions did not retain reliable clock times. I have stated that directly instead of adding estimated times. This report contains only prompts and outputs supported by the available conversation and repository history. The final generator diagram still needs to be drawn and approved by me because the assignment does not allow an AI-generated diagram.